

Linee Guida per il Trattamento dei Dati — per Volontari e Staff

Regole operative pratiche per chi collabora alla campagna «Conosci la FMD». Obiettivo: proteggere le persone e rispettare il ****GDPR (Reg. UE 2016/679)****. In caso di dubbio, ****fermati e chiedi**** al referente privacy: [contatto].

1. I principi in una frase

****Raccogli meno dati possibile, solo per uno scopo chiaro, solo con consenso, tienili al sicuro, e cancellali quando non servono più.****

2. Le 7 regole d'oro

1. Minimizza. Non chiedere dati che non ti servono. Mai chiedere dati sanitari se non indispensabile e senza consenso esplicito.

2. Sii trasparente. Ogni volta che raccogli dati, mostra o linka l'****Informativa Privacy**** e spiega a cosa servono.

3. Chiedi il consenso giusto. Newsletter, testimonianze e dati di salute richiedono consensi **separati e specifici** (vedi [modulo-consenso.md](#)).

4. Proteggi. Usa password robuste, autenticazione a due fattori, dispositivi bloccati. Non salvare dati personali su chiavette o dispositivi personali non protetti.

5. Non divulgare. Non condividere elenchi di contatti o storie di pazienti fuori dal team autorizzato. Non fare screenshot di conversazioni private.

6. Rispetta i diritti. Se qualcuno chiede di accedere, correggere o cancellare i propri dati, **inoltra subito** la richiesta al referente privacy.

7. Segnala gli incidenti. Se sospetti una perdita o un accesso non autorizzato ai dati, avvisa **immediatamente** il referente privacy (vedi sezione «Data breach»).

3. Cosa fare / cosa non fare

Fai:

- Usa gli account e gli strumenti ufficiali della campagna.
- Tieni separati i dati per finalità (newsletter ≠ testimonianze).
- Anonimizza le storie quando possibile.
- Chiudi le richieste di dati appena esaurita la finalità.

Non fare:

- Non chiedere diagnosi o dettagli clinici nei **commenti pubblici** dei social.
- Non pubblicare nomi, foto o storie **senza liberatoria firmata**.

- Non inviare e-mail collettive con gli indirizzi in chiaro: usa **CCN (Bcc)** o la piattaforma di newsletter.
- Non usare i contatti raccolti per finalità diverse da quelle autorizzate.
- Non conservare dati «per ogni evenienza».

4. Gestione dei dati di salute (categorie particolari — Art. 9)

- Trattali **solo** con **consenso esplicito** e per la finalità dichiarata.
- Conservali separati e ad accesso ristretto.
- Nelle comunicazioni pubbliche, **anonimizza** salvo consenso esplicito a essere identificati.
- Non richiedere mai dati di salute come condizione per iscriversi o partecipare.

5. Social media e messaggistica

- Se una persona condivide pubblicamente informazioni sensibili in un commento, ****non** amplificarle******; se opportuno, invitala gentilmente in un canale privato e sicuro.
- Per conversazioni private (es. gruppi di supporto), usa strumenti che offrano garanzie adeguate e informa gli iscritti su come sono trattati i loro dati.
- Ottieni sempre il consenso prima di **ripubblicare** contenuti altrui che contengano dati personali.

6. Fornitori (Responsabili del trattamento)

Ogni strumento esterno (hosting, newsletter, moduli, analytics) deve:

- essere **approvato** dal referente privacy;
- avere un **accordo di trattamento dati (DPA, Art. 28)**;
- offrire garanzie adeguate, preferibilmente con dati **nell'UE/SEE**.

Non attivare nuovi strumenti che trattano dati personali senza approvazione.

7. Conservazione e cancellazione

- Segui i tempi indicati nell'**Informativa Privacy** (sezione retention).
- Cancella o anonimizza i dati non più necessari.
- Alla fine di un'attività (es. un evento), elimina gli elenchi temporanei.

8. In caso di violazione dei dati (data breach)

Se sospetti una violazione (dati persi, rubati, esposti o inviati alla persona sbagliata):

- 1. Non nasconderla.** Avvisa **subito** il referente privacy: [contatto].
- 2.** Annota **cosa è successo, quando, quali dati e quante persone** sono coinvolte.
- 3.** Il Titolare valuterà se notificare al **Garante entro 72 ore** (Art. 33) e se informare le persone interessate (Art. 34).
- 4.** Non tentare di risolvere da solo/a: segui le indicazioni del referente.

9. Formazione e accettazione

Ogni volontario/a, prima di trattare dati personali, dichiara di aver letto e compreso queste linee guida e si impegna alla riservatezza.

Nome: _____ · Data: _____ · Firma: _____

*Riferimenti: Reg. (UE) 2016/679 (GDPR); D.Lgs. 196/2003 e D.Lgs. 101/2018; indicazioni del

Garante per la protezione dei dati personali — <<https://www.garanteprivacy.it/>>.*